

ESTUDO DE CASO 1

Direito e Segurança Digital

Plataforma ConectaCampus

Análise integrada de proteção de dados, segurança da informação e responsabilização

Integrantes

Alessandro de Oliveira Portela

Francisco Matheus Vasconcelos Evangelista

Francisco Pherdinnan Freire de Araujo

Luiz Guilherme dos Anjos de Araujo

Disciplina: Direito e Segurança Digital

1. IDENTIFICAÇÃO DOS PROBLEMAS

Problemas relacionados à coleta de dados

A plataforma solicita informações além das necessárias às funcionalidades acadêmicas, como fotografia, localização aproximada, contatos armazenados no celular, identificador do dispositivo, histórico de acesso, páginas visualizadas e tempo de permanência.

Ausência ou deficiência de transparência

A finalidade apresentada ao estudante é genérica: os dados seriam utilizados para “melhorar a experiência do usuário”, sem explicar claramente as demais utilizações.

Eventual inadequação do consentimento

O acesso às funcionalidades acadêmicas fica condicionado à autorização de localização, contatos e personalização de anúncios. Os termos completos aparecem em um link ao final da tela e possuem 38 páginas.

Incompatibilidade ou desvio de finalidade

Dados coletados para uma plataforma acadêmica também foram usados para publicidade e perfilamento, incluindo empréstimos, cursos particulares, apostas esportivas, eventos, planos de telefonia e anúncios relacionados a posicionamentos políticos.

Coleta excessiva

Foram solicitados dados adicionais sem finalidade claramente relacionada às funcionalidades acadêmicas apresentadas.

Perfilamento dos estudantes

A PublicData analisou comportamento e cruzou navegação, localização e horários de acesso para criar perfis sobre renda provável, interesses, hábitos de consumo, abandono do curso, deslocamentos e preferências políticas.

Compartilhamento com terceiros

Os dados foram compartilhados com a PublicData, enquanto os estudantes receberam apenas uma informação genérica sobre compartilhamento com “parceiros estratégicos”.

Conservação por período indeterminado

As informações eram mantidas sem prazo definido.

Dados reais em ambiente de testes

Cópias do banco de dados eram utilizadas em testes sem anonimização.

Falhas de controle de acesso

Havia contas administrativas compartilhadas e ausência de autenticação multifator.

Falhas no desligamento de empregados

A conta de Renato permaneceu ativa após seu desligamento.

Deficiência dos registros de auditoria

Os registros estavam incompletos, dificultando a reconstrução das atividades.

Demora na detecção do incidente

Acessos atípicos foram identificados, mas o incidente só foi confirmado 25 dias depois.

Comunicação insuficiente aos titulares

A Edutech informou apenas uma “instabilidade temporária”, sem esclarecer os dados acessados, o número de afetados ou as medidas que deveriam ser adotadas.

2. CLASSIFICAÇÃO DOS DADOS

Dados pessoais

Nome completo, CPF e data de nascimento, além de informações como endereço, telefone e e-mail.

Dados pessoais potencialmente sensíveis ou de maior risco

A combinação de fotografia, localização, contatos, identificadores e preferências políticas inferidas pode ampliar significativamente os riscos aos titulares. A natureza e a forma de utilização de cada informação devem ser consideradas.

Dados inferidos

A PublicData cruzou rastros de navegação, localização e horários para inferir provável faixa de renda, interesse em empréstimos, probabilidade de abandono do curso e preferências políticas.

Dados técnicos

Identificador do dispositivo e informações relacionadas ao funcionamento e à identificação de acessos e dispositivos.

Registros de acesso

Registros de autenticação, endereços IP, datas e horários, identificadores de dispositivos, comandos administrativos, histórico de exportação e logs de banco de dados.

Informações que podem aumentar o risco para os titulares

Nomes, e-mails, números de telefone, cursos, instituições e localizações aproximadas de 500 estudantes.

Combinação de dados

Informações aparentemente comuns podem se tornar altamente invasivas quando cruzadas, permitindo construir um perfil detalhado do estudante e aumentar riscos de fraude, abordagem direcionada e uso indevido.

3. LEGISLAÇÃO APLICÁVEL

Norma	Pontos relevantes	Aplicação
Constituição Federal	Art. 5º, X: intimidade, vida privada, honra e imagem; LXXIX: proteção de dados pessoais; LVII: presunção de não culpabilidade.	Proteção da esfera privada e dos dados; análise sem declarar culpados antes das provas.
LGPD – Lei nº 13.709/2018	Princípios do art. 6º; bases legais; consentimento e transparência; direitos dos titulares; segurança e prevenção; responsabilização por danos; incidente de segurança.	Principal norma para avaliar coleta, finalidade, perfilamento, compartilhamento, segurança e resposta ao incidente.
Marco Civil – Lei nº 12.965/2014	Privacidade, proteção de dados e registros; deveres ligados a tratamento e guarda, conforme o papel do provedor.	Complementa a proteção de dados no ambiente de internet e os deveres sobre registros.
CDC	Pode incidir se caracterizada relação de consumo.	Reforça dever de informação e possível responsabilidade do fornecedor.
Código Civil	Ato ilícito e dever de reparar danos, conforme arts. 186 e 927.	Pode fundamentar reparação por danos materiais e morais, conforme conduta, dano e nexo.
Código Penal	Art. 154-A trata da invasão de dispositivo informático sem autorização e com finalidade prevista em lei.	Senha ainda válida não resolve, por si só, a questão da autorização.

Norma	Pontos relevantes	Aplicação
Contratos	Edutech–PublicData–NuvemSegura–instituições.	Devem ser analisados para verificar obrigações, limites de uso, segurança e repartição de responsabilidades.

4. AGENTES, RESPONSÁVEIS E RESPONSABILIZAÇÃO

Agente	Papel provável	Possíveis responsabilidades a investigar
Edutech	Principal decisória sobre dados, finalidades, permissões, aplicação e retenção.	Civil e administrativa por tratamento e segurança; contratual perante parceiros; eventual responsabilidade por falhas de governança.
PublicData	Empresa contratada para analisar comportamento e criar perfis.	Verificar se atuou como operadora, controladora ou em posição compartilhada, conforme as decisões efetivamente tomadas. Pode responder por tratamento irregular.
NuvemSegura	Infraestrutura em nuvem e tarefas de segurança previstas no contrato.	Verificar cumprimento contratual, controles e comunicação de incidentes. A obrigação contratual não transfere automaticamente todas as decisões de tratamento.
Instituições de ensino	Contratantes e usuárias da plataforma; alegam finalidade acadêmica.	Verificar o que sabiam, o que contrataram e se participaram da definição de finalidades ou compartilhamentos.
Renato	Ex-administrador que acessou, copiou, apagou logs e divulgou dados sem autorização atual.	Possível responsabilidade individual civil, contratual/disciplinar residual conforme vínculo e, em tese, penal, dependendo do enquadramento e da prova.
Dirigentes	Receberam relatório e adiaram correções.	Investigar conhecimento, dever funcional, decisões concretas e nexos com danos; não presumir responsabilidade automática.
Profissionais de segurança/permissões	Responsáveis pela operação técnica.	Apurar atribuições, procedimentos, alertas recebidos e eventual falha individual ou sistêmica.

5. ALEGAÇÃO DE RENATO

Não. Uma credencial tecnicamente ativa não significa, por si só, autorização jurídica para continuar acessando o sistema.

Renato sabia que era ex-administrador e acessou deliberadamente o painel sem autorização atual. Além de consultar informações, copiou o banco, apagou registros, ofereceu os dados a uma empresa de publicidade e divulgou uma amostra.

Conclusão central: senha válida ≠ autorização válida.

- Autenticação técnica: confirma que uma credencial foi aceita pelo sistema.
- Autorização jurídica: depende da existência de permissão legítima.
- Existência de credencial: significa que a conta ou senha continua tecnicamente habilitada.
- Permissão legítima de acesso: exige autorização atual para acessar e realizar as operações.

O eventual enquadramento no art. 154-A do Código Penal depende dos elementos concretos do tipo penal e das provas disponíveis.

6. EVIDÊNCIAS NECESSÁRIAS

Evidência	O que pode demonstrar
Logs de autenticação	Quem entrou, quando, de onde e com qual conta.
IP, dispositivo e horários	Correlacionar acessos com Renato e outros sistemas.
Comandos administrativos	Identificar consultas, exportações, exclusões e demais ações.
Logs de banco de dados	Confirmar leitura, cópia e alterações.
Histórico de exportação	Verificar extração do banco e volume de dados.
Contratos	Definir obrigações das partes.

Evidência	O que pode demonstrar
Relatório de auditoria	Comprovar que riscos já haviam sido identificados antes do incidente.
Registros de desligamento	Demonstrar a data de saída e quando o acesso deveria ter sido revogado.
Versões dos termos e evidências do consentimento	Reconstituir o que foi informado e efetivamente aceito.
Mensagens aos titulares e amostras divulgadas	Demonstrar alcance do incidente e conteúdo exposto.
Cópias forenses e cadeia de custódia	Preservar integridade e confiabilidade da prova digital.

7. MEDIDAS CORRETIVAS

Prioridade	Medida	Objetivo
Imediata	Revogar acessos de desligados e individualizar contas.	Eliminar acessos órfãos e aumentar rastreabilidade.
Imediata	Ativar autenticação multifator para contas privilegiadas.	Reduzir risco de comprometimento de credenciais.
Imediata	Preservar logs e realizar cópia forense.	Evitar perda de evidências e permitir investigação.
Imediata	Ativar plano de resposta a incidentes e avaliar comunicação.	Conter o incidente, avaliar riscos e cumprir deveres aplicáveis.
Alta	Aplicar privilégio mínimo e segregação de funções.	Limitar o que cada conta pode acessar e fazer.
Alta	Separar produção e testes; anonimizar/pseudonimizar dados de teste.	Reduzir exposição de dados reais.
Alta	Melhorar logs e monitoramento de acessos atípicos.	Detectar comportamentos suspeitos com mais rapidez.
Alta	Revisar coleta, finalidades e bases legais.	Reduzir dados e adequar cada tratamento à sua finalidade.
Média	Revisar contratos e papéis de controlador/operador.	Definir responsabilidades, instruções e deveres de segurança.
Média	Capacitar profissionais e formalizar procedimentos de desligamento.	Evitar falhas humanas e administrativas previsíveis.
Média	Adotar privacidade e segurança desde a concepção.	Incorporar proteção de dados ao desenvolvimento do produto.

8. CONCLUSÃO

O Caso ConectaCampus apresenta uma combinação de problemas de proteção de dados, segurança da informação, transparência e governança. A análise não deve concentrar toda a responsabilidade em Renato, pois o incidente foi favorecido por falhas anteriores, como a manutenção de sua conta após o desligamento, a ausência de autenticação multifator, o uso de contas compartilhadas, registros incompletos e o adiamento das correções.

Ao mesmo tempo, a conduta de Renato deve ser analisada individualmente, considerando o acesso deliberado sem autorização atual, a cópia do banco, a exclusão de registros e a divulgação de informações. A responsabilização de cada agente depende das decisões efetivamente tomadas, das obrigações assumidas e das provas disponíveis.

A principal conclusão é que segurança digital e proteção de dados exigem governança, controle de acessos, transparência, minimização de dados, gestão adequada de terceiros, resposta a incidentes e proteção desde a concepção do sistema.